WALL·E

Prevent abuse of Interactive Research Environments

Mira Kuntz

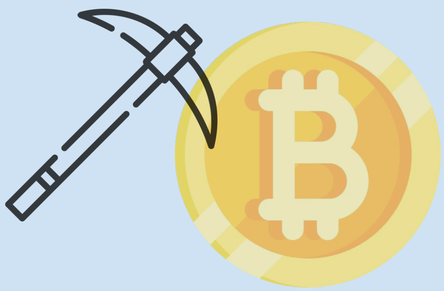
Freiburg Galaxy Team, Bioinformatics Group, Department of Computer Science, University of Freiburg, Germany

Galaxy EUROPE

Threats

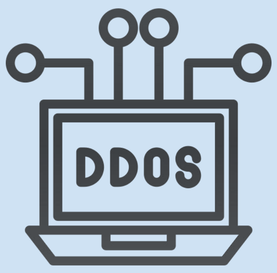
While Interactive Research Environments (IREs) in Galaxy lower the barriers to science by providing free, publicly available resources and privileged command line access, the ability to install packages and execute arbitrary code does not attract only legitimate users. We will briefly discuss two common attack motivations:

Cryptomining



- Attackers exploit compute resources like CPU and GPU to mine cryptocurrencies
- **Resource intensive** cryptographic algorithms
- High energy consumption and blocking of resources
- **High financial losses** for the victims[1]

Botnet attacks



- Attackers use victims' compromised servers as botnet for attacking other targets
- massive port scans or DDoS attacks
- IP addresses are tracked and listed in public databases
- **Compromises the victims reputation**

Both crypto mining and massive port scanning can be carried out as simple as downloading a single binary on the victim's server and execute it. Of course there are way more complex attack scenarios, but these are two widely established exploits that can be leveraged with minimal effort and background knowledge.

[1]Darabian, H., Homayounoot, S., Dehghantanha, A. et al. Detecting Cryptomining Malware: a Deep Learning Approach for Static and Dynamic Analysis. J Grid Computing 18, 293–303 (2020). https://doi.org/10.1007/s10723-020-09510-6

Comparing common strategies

Dynamic analysis

- Behavior-based
- Specialized monitoring mechanisms
- API calls, graphs
- Network traffic
- Machine learning (ML) supported[2]

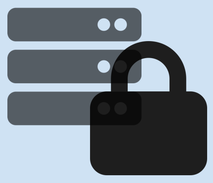
+ Detects poly- and metamorphic malware[3]	- Time consuming - Usually expensive - (Some) more false positive

Static analysis

- Detection can happen before malware runs
- Calculate hashes ("signatures") of files and compare them to a database
- "Classic" malware detection
- Open-source software available[4]

+ Less false positive + Reliably detects known malware + Fast[2]	- Can not detect polymorphic malware

Lockdown



- Authenticate users (e.g. by Organization)
- Reduce resources per user
- Tighten permissions
- Restrict network access
- IP blocklists

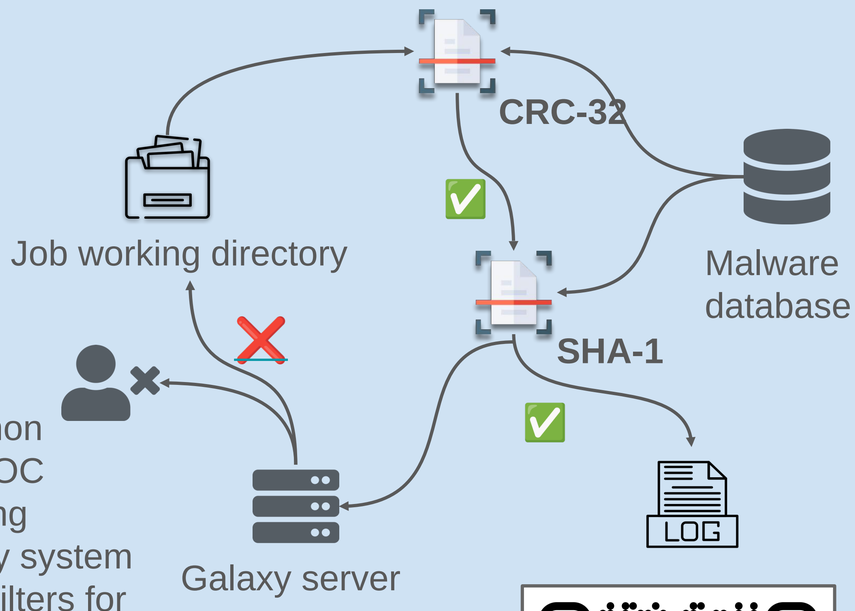
+ Easy to implement + No resource consumption	- Contradictory to open science - Less functionality - Difficult for IREs

[2]Y. Supriya, G. Kumar, D. Sowjanya, D. Yadav and D. L. Kameshwari, "Malware Detection Techniques: A Survey," 2020 Sixth International Conference on Parallel, Distributed and Grid Computing (PDGC), Waknaghat, India, 2020, pp. 25-30, doi: 10.1109/PDGC50313.2020.9315764

[3]Z. Bazrafshan, H. Hashemi, S. M. H. Fard and A. Hamzeh, "A survey on heuristic malware detection techniques," The 5th Conference on Information and Knowledge Technology, Shiraz, Iran, 2013, pp. 113-120, doi: 10.1109/IKT.2013.6620049

[4]e.g. ClamAV: https://www.clamav.net

WALL·E



- Written in Python
- Small: ~500 LOC
- Verbose logging
- 3-level severity system
- Optimisation: filters for file size, access time and tool ID
- 2-step-scanning minimizes false positives
- Optional: Delete malicious users via API
- Annotated YAML signature database (see right box)
- Contributions are always welcome (scan it!)

https://github.com/usegalaxy-eu/WallE

Deployment

- Get the Ansible role (QR code)
- Make sure to install all dependencies
- Ensure read access to Galaxy's database, configuration and the JWDs
- Customize the variables
- Malware database is automatically updated every time Ansible runs

https://galaxy.ansible.com/ui/standalone/roles/usegalaxy_eu/walle

Intergalactic-most-wanted-list (Malware database)

- Human-friendly YAML
- Signature creation and annotations are explained in the readme
- Share your knowledge and add new signatures to the database, whenever you detect malware

https://github.com/usegalaxy-eu/intergalactic-most-wanted-list

Contact

Freiburg Galaxy Team

contact@usegalaxy.eu

https://bawü.social/@galaxyfreiburg

Graphics

- DDoS icon created by Muhammad_Usman - Flaticon
- Picaxe, Bitcoin, file scan and log file icon provided by Freepik
- Python, Ansible and GitHub logos are property of their respective owners. The project is not associated to any of them,
- All other Icons are provided by Font Awesome

Funding

- European Unions HORIZON-INFRA-2021-EOSC-01, Grant Agreement no 101057388 (EuroScienceGateway)
- European Unions HORIZON-INFRA-2021-EOSC-01, Grant Agreement no 101046203 (BY-COVID)
- https://cordis,europa.eu/project/id/732703
- European Unions HORIZON-CL6-2021-BIODIV-01-01, Grant Agreement no 101059492 (BGE)